

Rapporto di Internal Audit – Verifica dei presidi di Compliance 2026

Audit n. 07/2026 | Ambito: presidi antiriciclaggio, protezione dei dati, sicurezza degli accessi, reportistica alla clientela istituzionale e gestione dei reclami

Protocollo	IA/REP/2026/007
Data del rapporto	26 giugno 2026
Periodo esaminato	1 gennaio – 31 maggio 2026
Attività sul campo	4 maggio – 12 giugno 2026
Redatto da	Stefano Galli – Responsabile Internal Audit
Destinatari	Presidente del CdA; Amministratore Delegato; Comitato Rischi e Controlli; Collegio Sindacale; Responsabili delle aree auditate
Classificazione	Riservato

1. Premessa e perimetro

L'intervento è stato svolto in esecuzione del Piano di Audit 2026 approvato dal Consiglio di Amministrazione e ha avuto l'obiettivo di valutare l'adeguatezza e l'effettiva operatività dei presidi di conformità della Società, con particolare riferimento allo stato di attuazione della Circolare Regolatoria AML n. 14/2026 (prot. CMP/CIRC/2026/014), alla Policy di Protezione dei Dati Personali v3 (POL-DPO-003), alla gestione degli accessi ai sistemi informativi, ai controlli sulla reportistica prodotta per la clientela istituzionale e al processo di gestione dei reclami.

2. Metodologia e scala di valutazione

Le verifiche sono state condotte in conformità agli Standard internazionali per la pratica professionale dell'Internal Auditing, mediante interviste, analisi documentale, test di conformità su campioni statisticamente rappresentativi e analisi dei dati estratti dai sistemi. I rilievi sono classificati secondo la seguente scala di rischio: **Alto** – carenza che espone la Società a sanzioni, perdite o danni reputazionali significativi e richiede interventi immediati; **Medio** – carenza rilevante da sanare nel breve periodo; **Basso** – opportunità di miglioramento.

3. Giudizio complessivo

Sulla base delle evidenze raccolte, il sistema dei presidi di compliance è valutato **"Parzialmente adeguato"**. Sono stati formulati sei rilievi, di cui due a rischio alto, tre a rischio medio e uno a rischio basso. Le carenze più significative riguardano la completezza dell'adeguata verifica rafforzata e l'assenza di controlli strutturati sui tempi e sulla qualità della reportistica verso i clienti istituzionali.

4. Sintesi dei rilievi

ID	Rilievo	Rischio	Responsabile del rimedio	Scadenza
F-01	Adeguatezza verifica rafforzata incompleta sulla clientela ad alto rischio	Alto	Andrea Fontana (Compliance)	31/08/2026
F-02	Assenza di controlli four-eyes e di monitoraggio SLA sulla reportistica ai clienti istituzionali	Alto	Luca Marchetti (Risk & Reporting)	30/09/2026
F-03	Utenze attive di personale cessato e accessi privilegiati non ricertificati	Medio	Davide Conti (IT)	31/07/2026
F-04	Registro delle attività di trattamento non aggiornato per i nuovi trattamenti della piattaforma DT Comply 2.0	Medio	Chiara Moretti (DPO)	30/09/2026
F-05	Ritardo nel completamento della formazione AML obbligatoria	Medio	Andrea Fontana (Compliance) / HR	30/09/2026

ID	Rilievo	Rischio	Responsabile del rimedio	Scadenza
F-06	Registro reclami non riconciliato e tempi di risposta non monitorati	Basso	Luca Marchetti (Risk & Reporting)	31/10/2026

Tabella 1 – Sintesi dei rilievi, livello di rischio, responsabile e scadenza di rimedio concordata con il management.

5. Dettaglio dei rilievi

F-01 – Adeguata verifica rafforzata incompleta (Rischio: Alto)

Su un campione di 40 fascicoli di clientela classificata ad alto rischio (su un totale di 126 posizioni), 14 fascicoli (35%) risultano privi di documentazione aggiornata sull'origine dei fondi e/o di una verifica documentata del titolare effettivo rispetto al Registro dei titolari effettivi; in 3 casi relativi a PEP manca l'approvazione dell'alta dirigenza per la prosecuzione del rapporto. **Raccomandazione:** completare l'aggiornamento di tutti i 126 fascicoli entro la scadenza della Circolare AML (31/08/2026), con evidenza delle approvazioni. **Commento del management:** concordato; attivato supporto consulenziale esterno.

F-02 – Controlli sulla reportistica ai clienti istituzionali (Rischio: Alto)

La produzione dei report trimestrali di monitoraggio del rischio per i clienti istituzionali non prevede un controllo indipendente (four-eyes) prima dell'invio, né un monitoraggio sistematico dei livelli di servizio contrattuali. Nel periodo esaminato il 12% dei report è stato consegnato oltre il termine contrattuale, con ritardi fino a 9 giorni; in 2 casi sono stati riemessi report per errori nei dati di esposizione. **Raccomandazione:** introdurre un cruscotto SLA, un controllo di qualità formalizzato e una procedura di escalation. **Commento del management:** concordato; l'intervento sarà coordinato con la migrazione alla nuova piattaforma di reporting.

F-03 – Gestione degli accessi (Rischio: Medio)

Sono state rilevate 23 utenze attive riconducibili a personale cessato da oltre 30 giorni, di cui 4 con privilegi amministrativi; la ricertificazione semestrale degli accessi privilegiati non è stata effettuata nel secondo semestre 2025. **Raccomandazione:** revoca immediata e automazione del processo di *de-provisioning* collegato al sistema HR.

F-04 – Registro dei trattamenti (Rischio: Medio)

Tre trattamenti introdotti con la piattaforma DT Comply 2.0 (profilazione di rischio automatizzata, conservazione dei log applicativi, integrazione con fornitori cloud extra-UE) non sono censiti nel Registro ex art. 30 GDPR; per il trattamento di profilazione non risulta effettuata la valutazione d'impatto (DPIA). **Raccomandazione:** aggiornare il Registro e completare la DPIA prima dell'estensione della piattaforma ad ulteriori clienti.

F-05 – Formazione AML (Rischio: Medio)

Al 31 maggio 2026 il 58% del personale ha completato il modulo di formazione AML obbligatorio 2026; il tasso scende al 41% nella divisione Consulenza Finanziaria. **Raccomandazione:** piano di recupero con sessioni dedicate e monitoraggio settimanale.

F-06 – Gestione dei reclami (Rischio: Basso)

Il registro dei reclami non è riconciliato con le comunicazioni ricevute tramite i canali commerciali; non sono monitorati i tempi di risposta rispetto al termine interno di 30 giorni. **Raccomandazione:** centralizzare la registrazione e introdurre un indicatore dei tempi di evasione.

6. Prossimi passi

Il presente rapporto è trasmesso al Consiglio di Amministrazione per la presa d'atto e sarà esaminato nel dettaglio dal Comitato Rischi e Controlli. La Funzione Internal Audit effettuerà un *follow-up* sullo stato di attuazione delle azioni correttive entro il 30 novembre 2026.

RISERVATO

Milano, 26 giugno 2026

Stefano Galli

Responsabile Internal Audit

stefano.galli@datatrust-solutions.it